Security Requirements Specification (SRSec)

Event Management System (SE Mini Project)

1. Introduction

This specification defines the security protocols and constraints for the Event Management System. The objective is to safeguard system integrity, assure data confidentiality, and maintain the availability of event and user records against unauthorized access or exploitation.

2. Authentication and Identity Management

2.1 Password Security: User credentials must be hashed utilizing strong cryptographic algorithms (e.g., bcrypt or Argon2) with unique salts prior to database storage.

2.2 Session Management: Active sessions must utilize secure, HTTPOnly, and SameSite cookies or short-lived JSON Web Tokens (JWT) to mitigate Cross-Site Scripting (XSS) and session hijacking vulnerabilities.

2.3 Account Lockout: The system must enforce an account lockout mechanism following a predefined threshold of consecutive failed authentication attempts to thwart brute-force attacks.

3. Access Control and Authorization

3.1 Role-Based Access Control (RBAC): Privileges must be strictly demarcated among user tiers (Administrator, Event Organizer, Attendee).

3.2 Least Privilege: Users must be granted only the minimum permissions necessary to perform their designated functions. Specifically, Attendees must not possess modification privileges over event parameters.

3.3 Insecure Direct Object Reference (IDOR) Prevention: Server-side validation must occur on all object references to ensure the authenticated user holds

authorization to access or modify the requested resource (e.g., event tickets or profiles).

4. Data Security and Privacy

4.1 Data in Transit: All client-server communications must be encrypted utilizing TLS 1.2 or higher (HTTPS).

4.2 Data at Rest: Sensitive Personally Identifiable Information (PII), including contact details and potential payment information, must be encrypted within the database.

5. Input Validation and Output Encoding

5.1 SQL Injection (SQLi) Mitigation: All database queries must employ parameterized queries or prepared statements via an ORM.

5.2 Cross-Site Scripting (XSS) Mitigation: All user-supplied input (e.g., event descriptions) must be subjected to strict sanitization upon input and context-aware encoding upon output to the presentation layer.

5.3 Cross-Site Request Forgery (CSRF) Mitigation: State-changing requests must mandate validation via anti-CSRF tokens.

6. Auditing and Logging

6.1 Security Event Logging: The application must record significant security events, including authentication successes/failures, privilege escalation attempts, and administrative modifications.

6.2 Log Sanitization: Log records must be strictly sanitized to exclude sensitive data such as plaintext passwords or unmasked PII.